

Security as Developer

Building, Testing & Monitoring Secure AI Agents · Omer Farooq

AGENT VS. AGENTIC

An **AI agent** handles a single task, such as summarizing one email thread or answering FAQs. An **agentic system** pursues a goal: it triages an inbox, diagnoses and closes a ticket, or migrates a repo until the build passes. More autonomy means more places to apply controls.

CONTROLS BY LAYER

LAYER	KEY RISKS	KEY CONTROLS
Perception	Prompt injection, poisoned sources	Injection detection, allow-listing, isolated parsing
Cognitive	Goal hijack, memory poisoning, excessive agency	Immutable prompt, per-task tool allow-list, short-lived tokens
Action	Malicious tools, vector poisoning, approval fatigue	Signed tool manifests, ACLs at ingest, show blast radius
Integration	Over-privileged accounts, shadow endpoints	No shared accounts, single gateway, outbound DLP
Operations	Denial of wallet, secrets in traces, jailbreak chains	Token quotas, redaction, CI red-team tests
Infrastructure	Sandbox escape, leaked keys, unsigned artifacts	Rootless containers, egress allow-list, SBOM and signing

OBSERVE AND DETECT DRIFT

- Trace every agent and tool call, and redact secrets from traces.
- Store audit trails in tamper-evident storage with restricted access.
- Set a baseline, monitor changes, and trigger re-evaluation or rollback when drift appears.
- Alert on agent-specific events: abuse, injection attempts and runaway loops.

ZERO TRUST ON EVERY CONTROL

Verify explicitly Authenticate and validate each request.	Least privilege Scoped, short-lived access per task.	Assume breach Contain, isolate and keep a kill switch.	Micro-segmentation Isolate tenants, users and memory.
---	--	--	---